ActivityRoster: full platform audit, 14 October 2026

14 October 2026 · code at `9a7abf2` plus this audit's fixes (production is `cc95bc6`) · follows the audit of 12 October (`docs/platform-audit-2026-10-12.md`)

Headline

Score: 8.3 / 10 (was 7.6). Recommendation: READY TO LAUNCH WITH CONDITIONS. No blockers left.

Both blockers from 12 October are fixed and proven:

- **Safety boat drivers are no longer judged on the course.** The "can they teach this course" check now runs only for places that count towards the ratio, and centres on instructor types have no separate driver at all.
- **Cancelling a session no longer pays it.** "Pay nothing" now clears both pay columns, so an edited amount can't survive.

All ten of the 12 October top 10 are fixed. In 45 commits since then, the roster moved to confirming day by day, places became RYA instructor types, Auto-roster's "Redo the whole week" became one all-or-nothing save, and receipts can be emailed into the books. The suite grew from 583 to 655 tests, and browser tests now run on every push.

One new problem matters before centres lean on Auto-roster: **undoing a "Redo the whole week" puts the whole week back as it was, wiping anything changed by hand since, for up to two weeks afterwards** (N09). It is proven by probe below and is the first recommendation.

---

1. How this audit was done, and its limits

Four kinds of evidence, named against every finding:

- **Code**: every commit since `a36e473` (the 12 October report) read, with the services and screens they touch: cancellation, places and instructor types, the problems list, assignment, confirm days, week redo and undo, PIN attempts, the hourly-job watch, receipts by email, sign-up, the roster example upload, the video route and the Dev Center actions.
- **Probe**: throwaway tests against a real SQLite database through the real services (not committed; results quoted). Four probes: cancel then restore an edited line, undo after a later change, the receipt inbox's sender checks, and impossible dates.
- **Browser**: the real app run locally with the demo centre (Lakeside Sailing Centre). Every office page as the owner, every app page as an instructor, the main pages signed out, and the public site, at laptop (1360 px) and phone (390 px) widths. Status, load time, sideways scrolling and browser console errors (including security-policy refusals) recorded for each.
- **Suite**: 147 test files, 655 tests, all passing at `9a7abf2`. Typecheck clean.

Limits:

- **No real phones, no live email, no Stripe, no production traffic.** Same as before.
- **The database's all-or-nothing saves can't be proven locally.** The test database runs statements one after another; only Cloudflare's database runs them as one unit. The code was read to confirm every multi-step save goes through the one batch helper.
- **Not every older finding was re-tested.** Section 3 says which were.

Priority: P0 = must fix before real centres rely on it · P1 = important before or early in real use · P2 = before scale · P3 = later.

2. What changed since 12 October

Area	What was added or changed
Instructor types	Places are RYA instructor types (Dinghy Instructor, Senior Instructor, Powerboat Instructor…), with ladders: a higher type can fill a lower place. A course map decides who can teach each course. Supervision warning when an instructor who needs a Senior Instructor is on with none on duty. Expired types warn. No separate safety boat driver: the instructor drives. Older RYA centres are moved over from the Dev Center (Preview, then Upgrade).
Roster	Confirm each day (Pending → Confirmed, staff told on confirming; undo); optional "staff accept their shifts"; cover judged per session; "Redo the whole week" planned first and saved in one go, only changes told, with undo; long saves show progress and wait 90 s
Courses	Real dates only; moving a staffed session warns about clashes first; time edits, pay and log saved together; who can teach each course in Course setup
Staff	Instructor type tick boxes everywhere; "Mark as left" takes the person off upcoming sessions (past pay kept)
Setup	Confirm-email link goes straight to choosing a PIN; guided wizard with essential and optional steps; ready-made invite message; upload an example of today's roster; dashboard checklist
Security	Strict nonce security policy enforced on signed-in pages; PIN attempts counted in one statement; machine secret only in a header; `/api/version` gives an opaque id; email when the hourly job stops
Reliability	Bulk notices queued for the delivery job instead of sent during the save; browser tests on every push
Dev Center	Finance log (director's loan, salary, dividends, capital); receipts attached to lines, by upload or by email, read and matched by Claude; CSP reports grouped by whose they are
Website	Twelve how-to videos and a two-minute explainer; Learning Centre follows the video order; wording says checks "can be switched on", licences not tickets; no Demo link in the header

3. The 12 October findings, re-checked

#	Finding (12 Oct)	Status now	Evidence
N01	Course check ran for every role, including safety boat drivers	**Fixed**	`lib/services/problems.ts` and `place-check.ts`: the course check runs only when the place counts towards the ratio; it's now a warning, not a block. Centres on instructor types have no driver place.
F01	Cancelling kept an edited pay amount	**Fixed**	`lib/services/cancel.ts` writes both pay columns; an approved line comes off approval with a note. Probe P1: nothing paid after "pay nothing".
N04 / F06	Website promised checks that new centres had switched off	**Copy fixed; default unchanged**	Website and guides now say instructor type, availability and Senior Instructor cover are always checked and the rest "can be switched on". Licence and ratio checks are still off for a new centre (`enforceLicenceChecks`, `enforceRatioChecks` default false). Now a product decision, not a false claim: recommendation 4.
N03	"Redo the whole week" not all-or-nothing	**Fixed**, but see N09	`lib/services/week-redo.ts`: plans first, saves the differences in one batch, tells only people whose shifts changed.
N02	Stall guard cancelled saves still working	**Fixed**	`ActionFailureWatcher`: progress after 2.5 s, gives up at 90 s, and then says the save may still be finishing.
F02	One-day adds skipped checks	**Fixed**	`session-staff.ts` uses the same place check as whole-course adds; a test confirms the licence check.

#	Finding (12 Oct)	Status now	Evidence
F04	Cover worked out three ways	**Fixed**	The problems list judges cover per session, as the board does.
F09	Leavers stayed on future sessions	**Fixed**	"Mark as left" lists and removes upcoming sessions; days worked keep their pay.
F07	PIN lockout beaten by parallel guesses	**Fixed**	`claimPinAttempt` counts the attempt in the same statement that checks the lock, before the PIN is checked.
F08	No alert when the hourly job stops	**Fixed**	`lib/ops/tick-watch.ts` : the two-minute job emails the owner once after two hours without a tick, and again when it's back. See N13.
F03	Editing a staffed session never blocked	**Fixed**	Clash warning before saving a new date or time.
F10	Expired instructor qualifications counted	**Fixed (warning)**	"Instructor type expired" on the problems list and in the picker; never blocks, by design.
F13	Impossible dates accepted	**Fixed**	Probe P4: 31 February and 29 February 2026 refused; 29 February 2028 accepted.
F14	Session time edits not all-or-nothing	**Fixed**	Times, pay lines and log in one batch.
F21	Courses page dates differed server vs browser	**Fixed**	"Today" comes from the server. No hydration errors in the browser run.
F26	Hourly job secret accepted in the URL	**Fixed**	Header only.
F27	A published week couldn't be unpublished	**Fixed by redesign**	Confirm days have undo.
F32	No end-to-end browser test in CI	**Fixed**	"Browser tests" workflow on every push: sign in, assign with the keyboard, confirm, undo.
F35	Notifications sent one by one inside the request	**Fixed for bulk**	Confirming a day queues email and push for the delivery job. Single notices still send at once (fine).
N05	Availability panel reads the whole week per click	**Open — P2**	`assignableForCellAction` still calls `getBoard` for the week.
N06	Redo told confirmed people twice	**Fixed**	Part of N03.
N07	`/api/version` showed the commit	**Fixed**	Opaque id.
N08	People picker not usable with arrow keys	**Fixed**	Arrow keys, Enter, Home/End, Escape; announced to screen readers.
F12	Breaks per session, not per day	Open — P2	Unchanged.
F39	No "cancel everything this afternoon"	Open — P2 (raised from P3)	Unchanged. Weather cancellations are an everyday event for sailing centres: recommendation 5.

Not re-tested: F15, F17–F20, F23–F25, F28–F31, F33, F34, F36, F38. Their code wasn't touched since 8 October, so that status stands.

4. New findings

P1

N09. Undoing "Redo the whole week" wipes later changes, for up to two weeks. - **Problem:** undo restores the week exactly as it was before the redo. Anything changed since, by hand or by another Auto-roster run, is reverted with it. The Change log offers Undo for 14 days, and nothing stops it reaching days already worked. - **Evidence:** Probe P2. A redo put Jo on Monday in place of Kim. The office then put Sam on a Wednesday session by hand. Undo reported "2 taken off, 1 put back": Kim back on Monday, and Sam gone from Wednesday though the redo never touched that session. - **Why it matters:** a week of careful hand fixes can disappear with one press, people are told they're off shifts they were given on purpose, and on past days the pay lines are rewritten. - **Where:** `undoRedo` in `lib/services/week-redo.ts`; the 14-day Undo button in `app/(app)/office/change-log/page.tsx`. - **Fix:** undo only the changes the redo made, and only where the session is still as the redo left it. Only from today on. Show what will change and ask before applying. Once a later change touches a session, leave that session alone and say so. - **Priority:** P1.

N10. Older RYA centres stay on the old places until the upgrade is run, and the upgrade is a bulk change to live data. - **Problem:** centres created before instructor types keep the generic Instructor / Senior / Assistant / Safety Boat Driver places and the old ratios until someone presses Upgrade in the Dev Center. The upgrade rewrites upcoming courses, places, pay rates and ratios for each centre. It's saved in chunks (resumable, "carries on where it left off"), not one unit per centre. - **Why it matters:** until it runs, those centres don't get the new checks, ladders or ratios. Running it straight on production goes against the working rule: test bulk updates on staging first and record the database's Time Travel bookmark. - **Fix:** press Preview on staging with a copy of a real centre, read the report, then record the bookmark and run Upgrade on production. The Dev Center could show the bookmark step on the button itself. - **Priority:** P1 (operational).

P2

#	Problem	Where	Fix
N11	One "Redo the whole week" is a single database batch. On a very big week (hundreds of changes plus pay lines) it may reach Cloudflare's per-request query limits.	`applyWeekState`	Time it on staging with a copy of the busiest real week; split by day if needed (each day still all-or-nothing).
N12	Restoring a cancelled session loses an amount the office had edited before cancelling: the line goes back to the roster rate.	`restoreSessions` in `lib/services/cancel.ts`; probe P1	Keep the edited amount in the cancellation note or a column, and put it back on restore.

P3

#	Problem	Where	Fix
N13	The "hourly job stopped" email is sent by the two-minute job, which runs on the same Cloudflare scheduler. If Cloudflare's scheduler stops altogether, nothing raises the alarm (the GitHub backup tick keeps the hourly work going, but nothing watches the two-minute job).	`lib/ops/tick-watch.ts`	Have the two-hourly GitHub probe also check the last tick time and email if it's stale.
N14	Receipts by email: the sender check uses the delivery address and, when present, the SPF result. With no SPF header the message is accepted. The real protection is the secret address.	`decideInbound`; probe P3	Also read Cloudflare's DKIM/DMARC result header and hold anything that fails.

#	Problem	Where	Fix
N15	The "Confirm my email" link now counts as full sign-in proof and stays usable for an hour.	`lib/auth/index.ts`	Make the link single use, or accept it only for an account with no PIN set yet.
N16	Undoing a confirmed day puts it back to Pending without telling anyone, so staff who saw "Confirmed" aren't told it changed.	`lib/services/roster-days.ts`	Tell people on that day when it goes back to Pending (in-app only).

5. Fixed during this audit

- **Website wording:** the homepage's "Run the season" step and the instructor sign-in door said staff can "swap" shifts. There is no swap feature, only open shifts, so both now say "pick up open shifts". The Dev Center sales mock-up said "Open shifts & swaps". A guide still said "safety boat ticket"; it now says "licence".
- **Dashboard:** the subtitle read "week of 2026-10-12"; it now reads "week of 12 October", like the rest of the app.
- **Checked and correct:** no remaining "Publish week", parental permission, working hours, "If the platform is down" or "checked on every assignment" claims. Safety boat driver now appears only where it's true: the upgrade text for older centres, the help answer saying there is no separate driver, and club duty names.

6. Browser results

Times are from the local development server (slower than production), after each page had been opened once.

Pages	Owner / instructor	Signed out	Time (local dev)	Notes
Dashboard, Roster (board and print view)	200	→ sign-in	2.4–4.3 s	Day strip shows Pending / Confirmed, undated licences and Confirm; cards coloured; "Every place filled · 4 problems" matches the red cards
Emergency sheet, Availability, Courses, Course setup, Import, Integrations, Instructors, Leave, Payroll, Settings (General and Pay), Change log, Billing, Equipment, Locations, Time clock	200	→ sign-in	1.5–2.9 s	
Instructor app: schedule, availability, leave, hours, documents, settings, notifications	200	→ sign-in	1.8–3.8 s	Shifts marked "Pending: your centre hasn't confirmed this day yet"
Emergency sheet download		→ sign-in		
Whole-centre export		404		Not reachable signed out
Public site: home, pricing, Learning Centre, compare, blog, contact, demo, privacy, terms, trust, diving	200		0.9–4.6 s	No Demo link in the header

- **No sideways scrolling** on any page at 1360 px or 390 px, signed in or out.

- **No security-policy refusals** on signed-in pages under the enforced nonce policy.
- **Console messages seen, none from production code:** React's development-only `eval` notice on public pages (production builds don't use it); missing video files (the local copy has no videos in storage, so the players stay hidden as designed); outside fonts and images blocked by this machine's network. One hydration warning on Settings → Pay appeared once and didn't come back in three reloads (most likely the local server reloading after an edit made during the run).
- **Dashboard** showed the raw date "week of 2026-10-12" (fixed, section 5).

---

7. Scores

Overall: 8.3 / 10 (12 October: 7.6). Roster, RYA functionality and payroll count double.

Area	12 Oct	14 Oct	Why it moved
UX	8.0	8.5	Day strip, progress on long saves, keyboard picker, guided setup, videos in the guides
Roster	7.5	8.5	False red cards gone, cover per session, redo all-or-nothing; held back by N09
Courses	7.5	8.0	Who can teach each course, real dates, clash warning on moves, one-batch edits
Availability	8.5	8.5	N05 still open
Staff	8.0	8.5	Instructor types on file, leavers come off upcoming sessions
RYA functionality	6.5	8.0	Ladders, course map, supervision and expiry warnings, RYA ratios; held back by checks off by default and older centres not yet upgraded (N10)
Payroll	7.0	8.0	Cancellation pay fixed; N12 minor
Equipment	7.5	7.5	
Mobile	7.5	7.5	App store accounts in progress; no phone testing yet
Security	8.0	8.5	Enforced nonce policy, atomic PIN count, header-only secret, opaque version
Privacy	9.0	9.0	Receipts reader listed in the subprocessors; nothing personal from centres reaches it
Multi-tenancy	9.5	9.5	`roster_day` is a tenant table and covered by the isolation test
Reliability	7.5	8.5	Queued notices, hourly-job alert, one-batch redo; N11 and N13 to check
Performance	7.0	7.0	N05
Testing	7.5	8.5	655 tests; browser tests on every push
Website / sales	8.0	8.5	Videos, honest claims, wording tidied

---

8. Top 10 recommendations, by business impact

1. **Fix Auto-roster undo (N09).** Undo only what the redo changed, only where nothing has changed since, only from today on, and show what will change first. Until then, don't use Undo after any hand changes.
2. **Press Deploy production.** Production is seven commits behind staging: the cleaned-up videos, the Learning Centre in video order, "Printing & the roster PDF", the "Morning roster email" heading, the header without Demo and the video lengths. Plus this audit's wording fixes.
3. **Upgrade older RYA centres to instructor types (N10).** Preview on staging first, record the Time Travel bookmark, then Upgrade on production, so every centre gets the ladders, course map and new ratios.

4. **Decide on safety checks for new centres (N04 / F06).** Recommended: licence and ratio checks on by default for RYA centres, with First Aid and Safeguarding mandatory. The website is honest either way now; this is about centres being protected from day one.
5. **Weather cancellations in one go (F39).** "Cancel everything this afternoon" with the pay rule and one message to everyone affected. Wind cancels sessions at sailing centres most weeks.
6. **Get the instructor app into the stores.** Apple and Google accounts are in progress. Then the Firebase push key, the Android signing key, the builds, the listings and universal links (`mobile/README.md`).
7. **One end-to-end day on staging.** Real emails (invites, codes, confirm-day notices), Stripe checkout and the customer portal, confirming a 40-person week, and a "Redo the whole week" on the busiest real week (N11).
8. **Speed up the availability panel (N05).** Read one day or reuse the week already loaded, so clicking around a big centre's week stays quick.
9. **Watch the scheduler from outside Cloudflare (N13).** Let the GitHub probe check the last hourly tick, so a full scheduler outage still emails you.
10. **Small tidy-ups: N12, N16, N15, N14.** Restore keeps an edited pay amount; staff hear when a confirmed day goes back to Pending; single-use confirm link; DKIM check on emailed receipts.

---

9. Production-readiness verdict

READY TO LAUNCH WITH CONDITIONS.

Conditions for the first centres: - Deploy production (recommendation 2) and run the instructor-types upgrade for any centre created before 12 October (recommendation 3). - Turn licence and ratio checks on in their Settings, and mark the checks they rely on as mandatory, until recommendation 4 is decided. - Don't press Undo on an Auto-roster run after making changes by hand, until N09 is fixed.

---

10. Manual testing still required

- On a phone: the instructor app, push notices, Face ID and the offline week (once the store builds exist).
- Email delivery for invites, sign-in codes, confirm-day notices and the morning roster email.
- Stripe checkout and the customer portal end to end on staging.
- Confirming a 40-person week and a "Redo the whole week" on a copy of a real centre's week on staging, timed.
- The instructor-types upgrade Preview on a copy of each older centre.
- Receipts by email: one real supplier receipt forwarded from Gmail, matched to its line.